

# API Dependabot

AI Engineering Capstone | One-page project summary | 28 September 2026

## Problem

When an API provider changes its OpenAPI contract, Java/Spring Boot teams must work out whether the change affects their Maven consumer and what to review before upgrading. API Dependabot connects deterministic contract comparison to evidence from the consuming repository.

## What the prototype does

| Input                                                                 | Analysis                                                                                                                  | Output                                                                                     |
|-----------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| Old and new OpenAPI 3.x files plus a local or GitHub Java repository. | Diff the contract, search Java source/tests, rank lexical evidence, and answer through paired Vanilla RAG or ReAct paths. | Contract changes, file/line evidence, and an advisory migration assessment with citations. |

## Architecture and active data surface

The deterministic diff is the source of contract facts. The repository surface supports local checkouts and shallow GitHub snapshots. A BM25-style lexical retriever indexes Java, tests, build metadata, README content, and diff evidence in bounded chunks. Vanilla RAG retrieves once; ReAct can inspect the diff, search/read Java, and retrieve more evidence with read-only tools and an eight-call limit. Spring AI provides model/tool integration; Promptfoo runs the paired evaluation.

## Evaluation snapshot

| Approach    | Latest six-case rerun       | Median latency | Tool calls |
|-------------|-----------------------------|----------------|------------|
| Vanilla RAG | 6/6 passed; mean judge 1.00 | 12.4 s         | 0          |
| ReAct       | 6/6 passed; mean judge 1.00 | 33.5 s         | 42 total   |

An earlier run exposed one unsupported ReAct impact claim about a request field. After adding a requirement for call-site or payload-mapping evidence, that case passed on rerun. Six development cases and one rerun are not a held-out study; these results do not select a final architecture.

## Scope and next step

The prototype is an advisory CLI, not a hosted Dependabot service. It does not edit code, run consumer tests in Docker, open pull requests, or deploy. Lexical matching may miss indirect or generated call paths. Next: add held-out cases, review answers manually, and compare quality with latency and tool use before deciding between approaches.

**Reproduce from the project root: set `OPENAI_API_KEY` and `SPRING_AI_MODEL_CHAT=openai`, then run `scripts/run-capstone-validation.ps1`. The evaluation makes live model calls.**